Security Review

Findings from the July 2026 internal review

Filex Demo Workspace

Internal document · July 2026

- Scope
- Authentication
- Share links
- Uploads
- Recommendations

Scope

The review covered authentication, authorisation, share-link handling and the upload pipeline of the Filex web application and its HTTP API. Infrastructure hardening of the hosting provider was out of scope.

Authentication

Interactive sessions use HTTP-only cookies rotated on every privilege change. Password authentication enforces a minimum of twelve characters and checks candidates against a breached-password list before accepting them.

Programmatic access uses long-lived API tokens scoped to a folder prefix. Tokens are stored hashed, shown to the user only once, and can be revoked from the account page. We recommend adding an expiry date to every new token by default.

Two-factor authentication via TOTP is available but not enforced for administrators. Enforcing it for the admin role is the highest-priority recommendation of this review.

Share links

Share links carry a 128-bit random token and can be protected with a PIN, an expiry and a maximum download count. Brute-force attempts against the PIN are rate limited per link and per source address.

Uploads

Uploaded files are stored with the declared name but served with a MIME type derived from content sniffing, and HTML uploads are always delivered as attachments. SVG previews are rendered inside a sandboxed iframe with scripts disabled.

Recommendations

Enforce two-factor authentication for administrators, default API tokens to a ninety-day expiry, and add an audit log entry for every share-link creation. All three items are tracked in the Q3 roadmap.